Ex2 Thursday (Day 1): full guide

One small step at a time. Do the step, tick it, move on. Do not read ahead. Today: **A. Malware** and **B. Threats and attacks**. Tomorrow: Autopsy, assurance, legal, justification.

Two things to settle BEFORE you start (not covered by me, your call):

☐ **Asking for help during the day.** You quoted a rule on 10 Nov: “no personal communication and/or on-line asynchronous interaction permitted”. Check with your assessor that it does not cover asking an AI assistant. Assume it does. This guide is written to be used on its own.

☐ **Sample and evidence ahead of time.** Ask whether you may download the malware sample and the M57-Jean image before the day. If not, do it in “Start of day”.

If you feel stuck (2 minutes):

1. Stand up, drink water, look away from the screen.
2. Say aloud: “The next step is ____.”
3. Write your assumption in one line, take a screenshot, move on. Come back at the end.

Time rule: when a box runs out, stop where you are, tick “partly done”, move on. A rough answer for every topic beats a perfect answer for half of them.

Targets: pass every criterion first. Then justify and compare (Merit). Extras last. Your Notion page says items 9 (malware) and 12 (threats) decide the grade, so their extras matter if time allows. Check the wording in your brief.

Schedule (6 hours, T+ = time since you started)

#	Block	Mins	T+	Clock	Done
1	Start of day: setup, brief, rules of engagement	30	0:30	____	☐
2	A. Malware (steps A1 to A5)	115	2:25	____	☐
	Break	10	2:35	____	☐
3	B1. Intel	25	3:00	____	☐
4	B2. Threat model	30	3:30	____	☐
5	B3. Scans	40	4:10	____	☐
	Break	10	4:20	____	☐
6	B4. Attack your own app	40	5:00	____	☐
7	Tidy, evidence log, upload	50	5:50	____	☐
8	Buffer or extras (items 9 and 12)	10	6:00	____	☐

If you are 15 minutes over anywhere, use the **cut list** on the last page.

1. Start of day (30 min)

Folders and notes (5 min)

☐ Make a folder **`Ex2_Day1`**. Inside: **`screenshots`**, **`outputs`**, **`notes`**.

☐ Open **`notes/evidence_log.txt`**. After every step add one line: figure number, what it shows, file name.

☐ Name screenshots in the order you will use them: **`fig01_sample_hash.png`**, **`fig02_triage_report.png`**.

☐ Open the Snipping Tool (**`Win+Shift+S`**).

☐ Start a timer. Write the start time on your tracker sheet.

Read the brief (10 min)

☐ Read the whole Ex2 brief once. Touch nothing.

☐ Highlight every verb (analyse, identify, test, justify, develop).

☐ Tick on your tracker which topics are highlighted yellow. Those are mandatory.

Rules of engagement (5 min)

Write this on the first page of **`notes/`** (it is part of the legal and ethics topic):

☐ Authorised by: me, for my own lab, for my own coursework.

☐ In scope: my Ex1 prototype app, my lab VMs, one malware sample inside an isolated VM, the M57-Jean image.

☐ Out of scope: any employer or CareLink system, any live site, anyone else's machine.

☐ Safety: VM snapshots before each test, revert after. No real personal data.

☐ Stop and escalate if anything touches something out of scope.

Get things running in the background (10 min). This saves time later.

☐ Start the lab VMs. Take a snapshot of each. Name it **`clean`**.

☐ Start your Ex1 prototype (Apache and MySQL). Follow **`ex1-design/prototype/README.md`**. Run **`bash test_sync.sh`** once. Expect 10 PASS.

☐ Note the IP of the machine running the app. From another VM use that IP, not **`localhost`**. Call it **`<TARGET>`**.

☐ Open Nessus (**`https://localhost:8834`**). Start the activation or plugin setup now. It can take 20+ minutes. Come back to it in B3.

☐ Get the **sample** (if not done already): log in to VirusShare in the lab VM only, download your chosen file. Never on a work laptop.

☐ Get the **M57-Jean image** for tomorrow. Record its SHA-256 (**`Get-FileHash -Algorithm SHA256 <file>`**). Do not open it today.

2. A. Malware (115 min)

Done when: you have a verdict, ATT&CK techniques, IOCs, a detection rule, and what CareLink should do.

A1. Safe setup (10 min)

☐ Lab VM only. Not your laptop, not the host.

☐ Snapshot **`clean`** exists. Network on **host-only or off** for static work.

☐ Defender may quarantine the download. Use an agreed exclusion folder inside the VM.

☐ Unzip. Zip password is usually **`infected`**: **`7z x sample.zip -pinfected`** (or **`unzip -P infected sample.zip`**).

☐ Rename to **`sample.bin`**. Never double-click it.

☐ Hash it:

Windows: **`Get-FileHash -Algorithm SHA256 .\sample.bin`**

Linux: **`sha256sum sample.bin`**

☐ Write the SHA-256 on your tracker. Screenshot it (**`fig01`**).

☐ Search that hash on VirusTotal. **Do not upload the file.** Note the family name and the detection count. Screenshot (**`fig02`**).

☐ In one line, say why this sample suits CareLink. Example: “Infostealers target saved credentials, like the sign-in details cached on 840 devices.”

A2. Static analysis (30 min)

The sample is **not run** in this step.

☐ Run the triage tool: **`python3 ex2-malware/triage.py sample.bin --yara ex2-malware/rules --md report.md --json report.json`**

☐ Open **`report.md`**. Screenshot the top (hashes, type, size, entropy) as **`fig03`** and the imports and ATT&CK table as **`fig04`**.

☐ Fill these on your tracker:

☐ File type and size

☐ MD5, SHA-1, SHA-256

☐ Compile timestamp (can be faked, say so)

☐ Sections and entropy. Above about 7 suggests packed or encrypted.

☐ Interesting imports (injection, persistence, network, anti-debug)

☐ YARA hits

☐ Strings: **`strings -n 8 sample.bin > notes/strings.txt`** (Windows: **`strings64.exe -n 8 sample.bin`**). Search it for: **`http`**, **`.exe`**, **`.dll`**, **`HKEY`**, **`Run`**, **`cmd`**, **`powershell`**, IP addresses.

☐ Copy any URLs, IPs, domains, registry keys and file paths onto the IOC table.

☐ If few imports and high entropy, write: “likely packed, so static view is limited”.

☐ Remember: **imports show capability, not proof of use.** Write that sentence in your notes.

☐ Optional if installed: Detect It Easy for packer and entropy, **`floss sample.bin`** for hidden strings.

A3. Dynamic analysis (45 min)

Plan before you click. Free sandbox time is short.

☐ Write your 4 questions: What processes does it start? What files and registry does it change? Where does it connect? Does it persist?

☐ Any.run: new task, upload **`sample.bin`**, pick a Windows option that suits the file (32 or 64-bit), set a run time (check the free-tier limits on the page).

☐ Know that free analyses are, I believe, public. Fine for a public sample. Never upload your own files or evidence.

☐ If Any.run will not run it, use your own CAPEv2 sandbox. Say in the write-up which you used and why.

☐ While it runs, screenshot:

☐ Process tree (**`fig05`**)

☐ Files created or changed, and registry keys, especially Run keys (**`fig06`**)

☐ Network: DNS names, IPs, HTTP requests (**`fig07`**)

☐ The ATT&CK or behaviour summary if shown (**`fig08`**)

☐ Copy IOCs from the report to your IOC table. Labels in the tool may differ: look for network, files, registry and IOC views.

☐ Note anything that looked like evasion: long sleeps, checks for a VM or debugger, nothing happening at all.

☐ Export or save the report if the tool offers it. Record the report link or file name.

A4. Compare static and dynamic (10 min)

☐ Fill the **Static vs dynamic** table on your tracker: agreed, only static, only dynamic.

☐ Write two lines: where they agree, and where they differ and why.

☐ Mark each ATT&CK technique as **confirmed** (seen in sandbox) or **suspected** (only imports or strings).

A5. Verdict, detection and CareLink actions (25 min)

☐ Verdict in one line: type (stealer, loader, RAT, ransomware), purpose, confidence.

☐ How it gets in (phishing email, malicious download), how it runs, how it persists, how it talks out, how it hides. Use those five headings.

☐ Write a YARA rule:

1. Copy a rule from **`ex2-malware/rules/generic_triage.yar`**.
2. Change the strings to ones from **your** sample.
3. Test it hits: **`yara -s myrule.yar sample.bin`**
4. Test it misses a clean file: **`yara myrule.yar C:\Windows\System32\notepad.exe`** (Linux: **`/bin/ls`**)
5. Screenshot both (**`fig09`**). Write what you changed.

☐ Detection, containment, mitigation for CareLink. For each, link to something already in your Ex1 design:

☐ Block the IOCs (DNS, firewall)

☐ EDR or Defender rule from your YARA

☐ Short-lived tokens and MFA limit what a stolen credential can do

☐ Small cache limits what a stealer can find

☐ Isolate the device, revoke its token, remote wipe

☐ Warn staff about the delivery route

☐ Revert the VM to **`clean`**.

A6. Extras (only after A5, item 9)

☐ **Obfuscation or evasion:** list what you saw (packing, dynamic API resolution, sleep, debugger or VM checks) and how you got past it (read the unpacked behaviour in the sandbox, dumped memory, waited out a sleep).

☐ **Your own script:** make a small, visible change to **`triage.py`** (for example, add a check for VM-detection strings). Write down exactly what you changed. Say plainly that the base tool is pre-written.

Break (10 min)

Stand up. Water. Eat something. Do not look at a screen for 5 minutes.

3. B1. Intel (25 min)

Done when: you have a short method, a sources list and 3 realistic threats for CareLink.

☐ Write the method in four words: **collect, check reliability, analyse, share.**

☐ List sources you would use and rate each A (reliable), B (usually), C (check it):

☐ NCSC (advice, alerts)

☐ CISA Known Exploited Vulnerabilities catalogue

☐ MITRE ATT&CK

☐ OWASP Top 10 (for the web app)

☐ Vendor reports for your malware family

☐ NHS England cyber alerts

☐ One line on dark web and social media: passive, lawful monitoring only, never engage.

☐ Pick **3 threats**, one technical, one human, one physical. Suggested:

1. Infostealer or ransomware on a staff device (from A).
2. Phishing that steals a sign-in and then a token.
3. Lost or stolen device holding cached visit notes.

☐ For each: asset, how it happens, impact, which Ex1 control helps.

☐ Screenshot or save one real source for each (a CISA entry, an ATT&CK page).

4. B2. Threat model (30 min)

Done when: one diagram and one STRIDE table.

☐ Draw the data flow of the Ex1 sync app (paper is fine):

External entity: clinician **device and app**

Flow 1: HTTPS from device to API

Process: **sync.php** API

Flow 2: SQL from API to database

Data stores: **notes** table, **api_tokens** table

Second entity: **IT admin**, who issues and revokes tokens

☐ Draw dashed lines for **trust boundaries**: device | internet | server | database.

☐ Label each flow with the protocol and the data (token, note).

☐ Fill the STRIDE table. Start from these and edit:

S/T/R/I/D/E	Threat	Existing control	How you test it
S	Stolen or guessed token posts fake notes	Hashed, scoped, expiring, revocable tokens	B4 brute force, revoke test
T	Note changed in transit	TLS only	Wireshark HTTP vs HTTPS
R	Staff deny writing a note	**`staff_id`**, **`created_at`**, logs without note text	Check a stored row
I	Error leaks SQL	**`display_errors`** off, generic 500	Tests 7 and 10, SQLMap

S/T/R/I/D/E	Threat	Existing control	How you test it
I	Cached notes read on a lost device	Disk encryption, PIN, small cache	OS hardening evidence
D	Flood of requests	64 KB cap, 413	B4 flood test (finding: no rate limit)
E	Read-only token writes	Scope check returns 403	Test 5
E	SQL injection reaches database	Prepared statements	SQLMap

☐ Mark the 3 highest risks (likelihood x impact, 1 to 5 each, same scale as Ex1).

☐ Screenshot or photograph the diagram (**`fig10`**) and the table (**`fig11`**).

5. B3. Scan your own app (40 min)

Only your own app, only in your lab. Target is **`<TARGET>`**, the machine running Apache.

☐ Snapshot or export the database first.

☐ **Nessus (start first, let it run):** New Scan, Basic Network Scan, target **`<TARGET>`**, save, launch. Do the others while it runs.

☐ **nmap:** **`nmap -sV -sC -p- -oN outputs/nmap.txt <TARGET>`**. Screenshot open ports and versions (**`fig12`**). Note anything that should not be open (MySQL 3306, FTP, SMB).

☐ **Nikto:** **`nikto -h http://<TARGET>/prototype/ -o outputs/nikto.txt`**. Note headers and files it flags (**`fig13`**).

☐ **dirb:** **`dirb http://<TARGET>/prototype/ -o outputs/dirb.txt`**. Note any file that should not be public, like **`db.php`** or backups (**`fig14`**).

☐ **Burp:**

1. Proxy tab, Intercept on, “Open browser”.
2. Send one valid request with **`curl -x http://127.0.0.1:8080 ...`** or the test script through the proxy.
3. Right-click the request, send to **Repeater**, change the token, send again.
4. Screenshot the request and response (**`fig15`**).

☐ When Nessus finishes: export the report. Record the top findings and severities (**`fig16`**).

☐ For each tool, write one line: what it found, whether it is real or a false positive, and what you would do.

6. B4. Attack your own app (40 min)

Snapshot the database before you start. Tests add rows. Clean up after.

Set your variables (use your real values):

```
TARGET=<TARGET>
URL=http://$TARGET/prototype/sync.php
TOKEN=<write token>
```

Attack 1: SQL injection with SQLMap (15 min)

☐ Run:

```
sqlmap -u "$URL" --method POST \
 --data '{"client_id":"sq1","staff_id":"s1","patient_ref":"P1*","note_text":"x","created_at":"20
26-11-12T09:00:00Z"}' \
 -H "Authorization: Bearer $TOKEN" -H "Content-Type: application/json" \
 --batch --level 3 --risk 1
```

☐ Expect: “does not appear to be injectable” because of prepared statements. That is a good result. Screenshot it (**`fig17`**).

☐ Write: worked? **No.** Impact if it had: read or change all notes. Why it held: parameterised queries. Residual: other endpoints, if any.

Attack 2: guess the token (10 min)

☐ Run 200 wrong tokens and count the responses:

```
for i in $(seq 1 200); do curl -s -o /dev/null -w "%{http_code}\n" -X POST \
 -H "Authorization: Bearer guess-$(printf %016d $i)" -H "Content-Type: application/json" \
 -d '{}' "$URL"; done | sort | uniq -c
```

☐ Expect: 200 x **`401`**. Screenshot (**`fig18`**).

☐ Finding: the endpoint answers every guess with no lockout or rate limit. Guessing is not realistic because tokens are long and random (check **`make_token.php`**), but the endpoint can be hammered.

☐ Fix: rate limit per IP and per token, alert on repeated 401s, tuned so it does not cause alert fatigue.

Attack 3: abuse cases (15 min)

Fill the table on your tracker. Use **`curl`** or Burp Repeater.

Test	Expect	What it proves
Read-only token tries to write	403	Authorisation works
Revoke a token in the database, then use it	401	Revocation works
Expired token	401	Expiry works
Same note sent twice	200, one row only	Safe to repeat
3 MB note	400 or 413	Size limit works
Malformed JSON	400, no SQL in the response	No information leak
`GET` instead of **`POST`**	405	Method check
Token sent over plain HTTP	Works if **`REQUIRE_HTTPS`** is false	Finding: set it true and retest

☐ “IDOR or bad upload” in the brief: this API has no read or upload function. Write “not applicable” and the reason. Do not invent a result.

☐ Pick **one** fix, apply it, and rerun the test to show it worked. For example, set **`REQUIRE_HTTPS`** to true and show HTTP now gets 403 and HTTPS still works.

☐ Clean up: delete the test rows or restore the database snapshot.

☐ Revert VMs to **`clean`**.

B5. Extras (only after B4, item 12)

☐ Threats to **processes**, not just technology:

☐ Helpdesk password or MFA reset by someone pretending to be staff

☐ Supplier or cloud vendor with admin access

☐ Leavers keeping tokens or devices

☐ A mitigation for each:

☐ Call-back to a known number plus manager approval before any reset

☐ Supplier access just-in-time, logged, with a named owner and contract clause

☐ Leaver checklist that revokes tokens and wipes the device on day one

7. Tidy, evidence log, upload (50 min)

☐ Evidence log: every figure has a number, a file name, what it shows and where you will use it.
☐ Rename or move screenshots so the numbers match the log.
☐ Hashes recorded: sample (SHA-256) and M57-Jean image (SHA-256).
☐ Copy outputs: triage report, YARA rule, nmap, Nikto, dirb, Nessus export, SQLMap output.
☐ Write 5 bullet notes for each of A and B using the 5 parts: what I did, why, evidence, alternative, remaining risk.
☐ Remove anything that must not be uploaded: the sample, real credentials, tokens.
☐ Check the brief for what must be uploaded each day. Upload what it asks.
☐ Confirm the upload shows as submitted.
☐ Save your work in two places.

Set up tomorrow (10 min)

☐ Autopsy installed and opens.
☐ M57-Jean image hashed and ready.
☐ Write on a sticky note: “Friday: E Autopsy, C assurance, D legal and IR, F justification, upload by 14:30.”

Cut list (if you are 15 minutes behind, drop in this order)

1. A6 and B5 extras
2. A2 optional tools (DIE, FLOSS)
3. B3: skip Nikto or dirb, keep nmap, Burp and Nessus
4. B4 attack 3: do the first 4 rows only
5. B2: shorter STRIDE (4 rows)

Never cut: one piece of evidence for every highlighted topic, the hashes, and the notes for tomorrow’s justification.

If something breaks

Tool will not install: describe what you would run, show the closest evidence, say plainly what you did not run.

Sample will not run in the sandbox: use static results plus public reports for the family, and cite them.

Prototype will not start: run `test_sync.sh` from the README. If it still fails, use the test table from your Ex1 submission as your baseline and say so.

Nessus will not activate: skip it, say so, and rely on nmap, Nikto and Burp.